

Dispensa di **Cybersecurity**

Prof. **Gianluigi Ferrari**

A.A. 2025–2026

Piattaforma Edvance — Digital Education Hub
Università di Pisa

A cura di

Federico Nardi



Sommario

Premessa.....	5
Cos'è Edvance	5
Le università partecipanti	5
Open Badge: utilità e riconoscimento	5
Cybersecurity 1 e Cybersecurity 2	6
Come è organizzata la dispensa.....	6
Nota di responsabilità.....	7
Capitolo 1 — Cyberspace, consapevolezza e obiettivi della sicurezza	9
1.1 Riservatezza, integrità e autenticità (la triade CIA)	9
Capitolo 2 — Account, identità digitale, autenticazione e autorizzazione.....	10
2.1 Autenticazione vs autorizzazione	10
Capitolo 3 — Password: robustezza, dizionario, brute force e password manager.....	11
3.1 Attacco del dizionario	11
3.2 Attacco brute force	11
3.3 Buone pratiche e password manager	12
Capitolo 4 — Autenticazione a più fattori (MFA) e SPID	13
4.1 Metodi MFA a confronto	13
4.2 SPID	13
Capitolo 5 — Crittografia: dal cifrario di Cesare alla crittografia moderna.....	14
5.1 Il libro dei codici	14
5.2 Cifrario di Cesare e aritmetica modulo 26	14
Capitolo 6 — Crittografia simmetrica, asimmetrica e ibrida	15
6.1 Crittografia simmetrica	15
6.2 Crittografia asimmetrica	15
6.3 Crittografia ibrida.....	16
Capitolo 7 — Firma digitale, hash, certificati e HTTPS.....	17
7.1 Firma digitale	17
7.2 Certificati digitali e Autorità di Certificazione (CA)	18
7.3 HTTPS	18
Capitolo 8 — HTTP, MITM, VPN, social engineering e crittografia post-quantistica	19
8.1 HTTP e attacco Man-in-the-Middle	19
8.2 VPN.....	19
8.3 Social engineering.....	19

8.4 Crittografia post-quantistica (PQC).....	20
Capitolo 9 — Privacy online: dati personali, consenso e profilazione.....	22
9.1 Perché difendere la privacy è difficile.....	22
Capitolo 10 — Cookie, GDPR, log server e dati che restano online	23
10.1 GDPR in parole semplici.....	23
10.2 Cancellare i cookie non cancella tutto.....	24
Capitolo 11 — Cronologia, modalità privata e sincronizzazione cloud	25
11.1 Perché la cronologia può essere rischiosa.....	25
11.2 Modalità privata: cosa fa e cosa non fa.....	25
Capitolo 12 — Fingerprinting: l'impronta tecnica del browser	26
12.1 Perché è un problema per la privacy.....	26
Capitolo 13 — Privacy nei social network.....	27
Capitolo 14 — Phishing: riconoscere l'inganno	28
14.1 Segnali tipici di un'email di phishing.....	28
14.2 Email legittima vs phishing	28
Capitolo 15 — Injection: SQL injection, command injection e XSS	29
15.1 XSS in parole semplici	29
15.2 Difese principali	29
Capitolo 16 — Software, trust, sandbox e aggiornamenti	30
16.1 Sandbox.....	30
16.2 Aggiornamenti e vulnerabilità	30
Capitolo 17 — Security by design e principi di progettazione sicura	31
17.1 Principi fondamentali.....	31
17.2 Perché costa meno pensarci prima	31
Capitolo 18 — Blockchain: registro distribuito, consenso, Proof of Work e mining	32
18.1 Consenso.....	32
18.2 Proof of Work e mining.....	32
18.3 Vantaggi e limiti	33
Capitolo 19 — Intelligenza artificiale e cybersecurity	34
19.1 AI per la difesa	34
19.2 AI per l'attacco	34
Capitolo 20 — Cybersecurity del futuro: prevenzione, rilevamento, risposta, resilienza.....	35
20.1 Dalla sicurezza assoluta alla resilienza.....	35
20.2 Scenari critici.....	35
Mappe finali dei concetti	36

Mappa Cybersecurity 1	36
Mappa Cybersecurity 2	36

Premessa

Cos'è Edvance

Edvance è il primo Digital Education Hub italiano dedicato alle competenze digitali avanzate, finanziato dall'Unione Europea — Next Generation EU nell'ambito del PNRR, Missione 4 "Istruzione e Ricerca". È coordinato dal Politecnico di Milano e riunisce attualmente diciassette tra università e istituzioni AFAM (Alta Formazione Artistica, Musicale e Coreutica), tra cui l'Università di Pisa. Il portale ufficiale www.edvance.it raccoglie oltre duecento corsi online gratuiti in formato MOOC (Massive Open Online Course), suddivisi in quattro aree strategiche: data literacy, intelligenza artificiale, transdisciplinarietà e sostenibilità digitale. I corsi sono accessibili tramite SPID o credenziali federate EduGain e sono rivolti a studenti, lavoratori, docenti, professionisti e cittadini, indipendentemente dal titolo di studio posseduto.

Le università partecipanti

La rete Edvance comprende atenei distribuiti su tutto il territorio nazionale. Tra i partner figurano il Politecnico di Milano (capofila), il Politecnico di Torino, l'Università di Torino, l'Università di Pisa, l'Università di Macerata, l'Università di Bologna, l'Università di Padova e altre istituzioni universitarie e AFAM. Ciascun ateneo contribuisce con i propri MOOC, mettendo a fattor comune competenze ed eccellenze didattiche.

L'Università di Pisa ha attivato in particolare il percorso *"Sempre Connessi: dietro le quinte di Internet"*, *"Cybersecurity 1"* e *"Cybersecurity 2"*, tenuti dal [Prof. Gian-Luigi Ferrari](#), oltre a corsi su *Intelligenza Artificiale*, *etica dell'IA*, *Internet of Things* e altri temi della cultura digitale avanzata.

Open Badge: utilità e riconoscimento

Al termine di ciascun MOOC, dopo il superamento dei quiz e delle attività di valutazione previste, la piattaforma rilascia un Open Badge: un attestato digitale standardizzato, verificabile e condivisibile. L'Open Badge contiene metadati che descrivono le competenze acquisite, l'ente erogatore, la data di rilascio e i criteri di ottenimento.

L'utilità degli Open Badge è duplice. Sul piano professionale, possono essere pubblicati su LinkedIn, inseriti nel curriculum o nel portfolio digitale e mostrati a datori di lavoro o committenti per certificare competenze specifiche. Sul piano accademico, in molti corsi di laurea i badge Edvance possono essere riconosciuti come CFU: il numero di crediti è deliberato dai singoli consigli di corso di studio, quindi è necessario consultare il proprio piano di studi.

Cosa NON è un Open Badge

Un Open Badge non è una laurea, non sostituisce un esame universitario tradizionale e **non garantisce in automatico il riconoscimento di CFU**: certifica il completamento del MOOC e il superamento delle relative valutazioni. Il riconoscimento accademico dipende dal regolamento del singolo corso di laurea.

Cybersecurity 1 e Cybersecurity 2

Questa dispensa rielabora i contenuti dei due MOOC Edvance/UniPi sulla cybersecurity, tenuti dal [Prof. Gian-Luigi Ferrari](#). I due percorsi sono complementari: il primo costruisce la consapevolezza di base sull'identità digitale, sulle password, sulla crittografia e sui canali sicuri; il secondo amplia lo sguardo a privacy, software, blockchain e intelligenza artificiale.

Badge	Contenuti principali	Cosa certifica
Cybersecurity 1	Identità digitale, password, MFA, crittografia simmetrica/asimmetrica, firma digitale, certificati, HTTPS, VPN, social engineering, crittografia post-quantistica.	Una base generale di consapevolezza e buone pratiche per proteggere account, comunicazioni e dati personali.
Cybersecurity 2	Privacy online, cookie, cronologia, fingerprinting, social network, phishing, injection, software, security by design, blockchain, AI e scenari futuri.	Una comprensione più ampia dei rischi moderni: privacy, sicurezza del software, tecnologie emergenti e uso consapevole dell'AI.

Come è organizzata la dispensa

Il testo è suddiviso in venti capitoli, raggruppati in due parti corrispondenti ai due MOOC. Ogni capitolo segue lo stesso schema: spiegazione discorsiva, tabelle di confronto, esempi pratici e box *“Da ripetere”* evidenziati in rosso, pensati come frasi sintetiche da memorizzare.

- Leggi prima la parte discorsiva per capire il senso degli argomenti.
- Ripeti i box rossi *“Da ripetere”*: sono formulati come risposte brevi.
- Usa le tabelle per confrontare concetti simili (autenticazione/autorizzazione, HTTP/HTTPS, simmetrica/asimmetrica, cookie/fingerprint).
- Alla fine usa la mappa finale come controllo attivo dello studio.

Nota di responsabilità

Questa dispensa è una rielaborazione didattica personale e non commerciale dei MOOC Edvance/UniPi *Cybersecurity 1* e *Cybersecurity 2*.

Non è un documento ufficiale di Edvance né dell'Università di Pisa, non sostituisce il materiale ufficiale del corso e non può essere venduta o presentata come prodotto commerciale. Per certificazioni, criteri di valutazione e aggiornamenti, fa fede esclusivamente il materiale ufficiale pubblicato sulla [piattaforma Edvance](#) e sulle pagine dell'[Università di Pisa](#).

L'autore non si assume responsabilità per eventuali errori, omissioni o usi impropri.

Buono studio!

Parte I

Cybersecurity 1: identità digitale e prime difese

La **Parte I** costruisce le basi: che cosa significa proteggere la propria identità digitale, come si difendono gli account, perché password e MFA sono centrali, e in che modo la crittografia permette di proteggere dati e comunicazioni. È la parte più vicina all'utente comune: insegna a non essere l'anello debole del sistema.

Capitolo 1 — Cyberspace, consapevolezza e obiettivi della sicurezza

Il cyberspace è lo spazio digitale in cui viviamo ogni giorno: siti web, reti sociali, piattaforme universitarie, app bancarie, sistemi cloud, servizi pubblici online, comunicazioni private. Non è uno spazio fisico, ma produce effetti reali: una password rubata può causare perdita di denaro; un messaggio manipolato può ingannare una persona; un dato sanitario esposto può violare la dignità di un paziente.

La cybersecurity è l'insieme di tecniche, regole, strumenti e comportamenti che servono a proteggere persone, dati, dispositivi, servizi e organizzazioni nel cyberspace. Non riguarda solo chi programma o amministra server: riguarda anche l'utente che sceglie una password, clicca un link, approva una notifica MFA o decide cosa pubblicare online.

 **Da ripetere** — La cybersecurity non è solo un problema tecnico, è anche umano e organizzativo. Ogni click, password o condivisione ha conseguenze. La parola chiave è consapevolezza.

1.1 Riservatezza, integrità e autenticità (la triade CIA)

Tre obiettivi tornano continuamente quando si parla di sicurezza informatica: riservatezza, integrità e autenticità. La riservatezza risponde alla domanda “chi non è autorizzato può leggere il dato?”. L'integrità risponde alla domanda “il dato è rimasto uguale o è stato modificato?”. L'autenticità risponde alla domanda “sto davvero parlando con la persona, il server o il servizio giusto?”.

Obiettivo	Domanda chiave	Esempio
Riservatezza	Chi non è autorizzato può leggere?	Un messaggio cifrato non deve essere leggibile da chi lo intercetta.
Integrità	Il dato è stato modificato?	Una firma digitale fallisce se il documento cambia anche di poco.
Autenticità	L'identità è quella giusta?	Un certificato HTTPS aiuta il browser a riconoscere il sito reale.

 **Da ripetere** — La firma digitale lavora soprattutto su autenticità, integrità e non ripudio. HTTPS lavora su autenticità del sito, riservatezza e integrità della comunicazione. La MFA rafforza l'autenticazione dell'utente.

Capitolo 2 — Account, identità digitale, autenticazione e autorizzazione

Nel mondo digitale una persona viene rappresentata da account. Un account è un'identità operativa: collega l'utente a servizi come email, home banking, social network, e-commerce, piattaforme universitarie e servizi pubblici. Se un account viene compromesso, l'attaccante può agire come se fosse il legittimo proprietario.

Proteggere un account significa proteggere identità, dati, reputazione e accessi collegati. Spesso l'email è l'account più critico, perché permette di recuperare le password di altri servizi: se l'email viene rubata, l'attaccante può tentare il reset di molti account collegati.

2.1 Autenticazione vs autorizzazione

Autenticazione e autorizzazione sono due concetti distinti che spesso vengono confusi.

L'autenticazione serve a dimostrare chi siamo; l'autorizzazione stabilisce cosa possiamo fare dopo essere stati riconosciuti.

Concetto	Significato	Esempio
Autenticazione	Dimostrare la propria identità al sistema.	Inserisco password e codice MFA.
Autorizzazione	Definire i permessi concessi all'utente autenticato.	Un utente normale legge i propri dati; un admin modifica impostazioni globali.
Minimo privilegio	Concedere solo i permessi strettamente necessari.	Un'app torcia non dovrebbe accedere ai contatti.

 **Da ripetere** — Autenticazione = dimostro chi sono. Autorizzazione = il sistema decide cosa posso fare. Un account compromesso permette all'attaccante di agire a nome dell'utente.

Errore frequente

Dire “ho la password, quindi posso fare tutto” è sbagliato. La password riguarda l'autenticazione; i privilegi riguardano l'autorizzazione. Un sistema sicuro controlla anche quali azioni l'utente autenticato può effettivamente compiere.

Capitolo 3 — Password: robustezza, dizionario, brute force e password manager

La password è spesso l'unico vero segreto dell'account: nome utente e email sono di solito pubblici o facilmente intuibili. Per questo una password debole rende debole l'intero accesso. Il problema non è solo che qualcuno la indovini manualmente: oggi esistono strumenti automatici capaci di provare grandissime quantità di password al secondo.

3.1 Attacco del dizionario

L'attacco del dizionario prova parole comuni e varianti prevedibili: nomi, date, squadre, città, animali domestici, parole presenti sui social, sequenze come "qwerty" o "password123". L'attaccante non deve necessariamente conoscere la vittima: sfrutta il fatto che molte persone scelgono password simili tra loro.

3.2 Attacco brute force

Nell'attacco brute force si provano tutte le combinazioni possibili entro un dato insieme di caratteri. La sicurezza cresce all'aumentare del numero di simboli disponibili e, soprattutto, all'aumentare della lunghezza. La formula da tenere in mente è:

$$N = S^L$$

dove

- N è il numero totale di combinazioni;
- S il numero di simboli ammessi nell'alfabeto;
- L la lunghezza della password.

La crescita è esponenziale in L : ogni carattere aggiunto moltiplica per S lo spazio di ricerca.

Esempio	Spazio di ricerca	Lettura intuitiva
PIN numerico 4 cifre	$10^4 = 10000$	Molto piccolo: senza blocchi si prova quasi istantaneamente.
4 lettere (maiusc./minusc.)	$52^4 \approx 7,3 \text{ milioni}$	Molto meglio del PIN, ma ancora troppo corto.
8 caratteri (lettere+numeri+simboli)	$94^8 \approx 6,1 \cdot 10^{15}$	Enorme: brute force diretto diventa impraticabile.
Pass-phrase lunga	Cresce molto con la lunghezza	Spesso più memorizzabile e robusta di una password corta strana.

3.3 Buone pratiche e password manager

- Usa password lunghe: la lunghezza pesa molto sulla resistenza al brute force.
- Usa password uniche: una password riutilizzata su più servizi amplifica il danno di una fuga dati.
- Evita informazioni personali (date, nomi, luoghi, animali, squadre): sono prevedibili e cercate per prime.
- Usa un password manager: permette di generare e custodire password casuali e diverse senza ricordarle tutte.
- Attiva la MFA dove possibile: anche una buona password può essere rubata tramite phishing o malware.

 **Da ripetere** — Una password robusta deve essere lunga, unica e non prevedibile. Il riutilizzo è pericoloso: se cade un servizio, possono cadere anche gli altri. Una password non deve essere salvata in chiaro: va conservata come hash con salt.

Hash e salt in parole semplici

Un servizio serio non salva la password leggibile. Salva un'impronta matematica chiamata hash, ottenuta con una funzione H non invertibile. Al login il sistema ricalcola $H(\text{password})$ e la confronta con quella salvata. Il salt è un valore casuale aggiunto prima dell'hash — formalmente si calcola $H(\text{salt} || \text{password})$ — per impedire l'uso di tabelle precompilate (rainbow table) e per rendere diversi gli hash di password identiche di utenti diversi.

Capitolo 4 — Autenticazione a più fattori (MFA) e SPID

L'autenticazione a più fattori (MFA, Multi-Factor Authentication) richiede almeno due prove diverse dell'identità. Il senso è semplice: anche se un attaccante scopre la password, non dovrebbe poter entrare senza superare anche un secondo controllo, basato su un fattore di tipo differente.

Fattore	Idea	Esempi
Qualcosa che sai	Un segreto memorizzato	Password, PIN, risposta a una domanda di sicurezza
Qualcosa che possiedi	Un oggetto o dispositivo fisico	Smartphone, app di autenticazione, token, chiave hardware (FIDO2)
Qualcosa che sei	Una caratteristica biometrica	Impronta digitale, volto, iride, voce

4.1 Metodi MFA a confronto

Il codice via SMS è meglio di nessun secondo fattore, ma non è il metodo più robusto: può essere esposto a SIM swap, intercettazioni o reindirizzamenti. Le app di autenticazione generano codici temporanei (TOTP) sul dispositivo e sono in genere più sicure degli SMS. Le notifiche push sono comode, ma vanno approvate solo se l'accesso è stato effettivamente iniziato dall'utente. Le chiavi hardware sono tra le soluzioni più resistenti al phishing perché legano crittograficamente l'accesso al sito corretto.

MFA fatigue

Un attaccante che già conosce la password può inviare ripetute richieste di approvazione MFA sperando che l'utente ne accetti una per stanchezza o distrazione. Regola pratica: se ricevi una notifica MFA che non hai richiesto, non approvarla mai e cambia subito la password del servizio.

4.2 SPID

SPID (Sistema Pubblico di Identità Digitale) è l'identità digitale italiana usata per accedere a servizi della Pubblica Amministrazione e a numerosi servizi privati. In pratica l'utente combina credenziali (qualcosa che sa) con un secondo fattore (app, SMS o OTP), realizzando di fatto una MFA gestita a livello nazionale e federato.

 **Da ripetere** — La MFA rende più costoso l'attacco perché non basta rubare la password. Non comunicare mai codici OTP e non approvare notifiche che non hai richiesto.

Capitolo 5 — Crittografia: dal cifrario di Cesare alla crittografia moderna

La crittografia serve a trasformare un messaggio leggibile (testo in chiaro, plaintext) in un messaggio incomprensibile (testo cifrato, ciphertext). Chi possiede la chiave corretta può ricostruire il messaggio originale; chi non la possiede dovrebbe vedere solo dati apparentemente casuali. La crittografia moderna non si basa sul tenere segreto l'algoritmo (**principio di Kerckhoffs**): al contrario, gli algoritmi più importanti sono pubblici e studiati apertamente. La sicurezza dipende dalla chiave, cioè dal segreto che permette di cifrare, decifrare o verificare.

5.1 Il libro dei codici

Un libro dei codici è una lista di corrispondenze in cui una parola apparentemente normale indica un significato nascosto. È utile per capire l'idea di chiave condivisa, ma non è adatto a Internet: se il libro viene rubato, tutto il sistema cade; inoltre è ingestibile su milioni di utenti.

5.2 Cifrario di Cesare e aritmetica modulo 26

Il cifrario di Cesare sposta ogni lettera dell'alfabeto di un numero fisso k di posizioni. Indicando con x la posizione della lettera ($A = 0, B = 1, \dots, Z = 25$), la cifratura e la decifratura si scrivono:

$$\begin{aligned}E_k(x) &= (x + k) \bmod 26^1 \\D_k(y) &= (y - k) \bmod 26\end{aligned}$$

Con chiave $k = 2$, la parola *MELA* diventa *OGNC*: $M \rightarrow O, E \rightarrow G, L \rightarrow N, A \rightarrow C$. Quando si supera Z si ricomincia da A : è il senso dell'operatore $\bmod 26$, come un orologio che dopo le 12 torna all'una.

Perché il cifrario di Cesare è debole

Le chiavi possibili sono soltanto 25 (oltre alla chiave nulla $k = 0$). Un attaccante può provarle tutte in pochissimi tentativi (attacco esaustivo) e scegliere il risultato che ha senso compiuto. Il cifrario serve per capire i concetti, non per proteggere comunicazioni reali.

 **Da ripetere** — Il cifrario di Cesare è un esempio di crittografia simmetrica: la chiave è lo spostamento k e cifratura/decifratura sono operazioni inverse *modulo 26*.

¹ $\bmod 26$: fa riferimento all'operatore in modulo 26

Capitolo 6 — Crittografia simmetrica, asimmetrica e ibrida

6.1 Crittografia simmetrica

Nella crittografia simmetrica mittente e destinatario usano la stessa chiave segreta k .

Detto

- $C = E_k(M)$ il testo cifrato;
- $M = D_k(C)$ la decifrazione.

Si ha:

$$D_k(E_k(M)) = M$$

È veloce e adatta a cifrare grandi quantità di dati (algoritmi tipici: *AES*, *ChaCha20*), ma ha un problema cruciale: Come si scambia la chiave in modo sicuro?

Se qualcuno intercetta k , può leggere tutto ciò che è cifrato con quella chiave.

6.2 Crittografia asimmetrica

Nella crittografia asimmetrica ogni utente possiede una coppia di chiavi:

- una pubblica pk , distribuibile a tutti;
- una privata sk , da tenere segreta.

La proprietà fondamentale è:

$$D_{sk}(E_{pk}(M)) = M$$

Se Alice vuole inviare un segreto a Bob, cifra con la chiave pubblica di Bob; solo Bob, possedendo la propria chiave privata, può decifrare.

Algoritmi classici: *RSA*, *Diffie-Hellman*, *crittografia su curve ellittiche (ECC)*.

6.3 Crittografia ibrida

La crittografia ibrida combina i due mondi: l'asimmetrica è utile per scambiarsi in modo sicuro una chiave di sessione; la simmetrica, molto più veloce, cifra effettivamente i dati. È lo schema usato da TLS, da SSH e dalla maggior parte dei protocolli moderni: si autentica e si scambia un segreto con l'asimmetrica, poi si passa a una chiave simmetrica temporanea per la comunicazione vera e propria.

Tipo	Chiave	Vantaggio	Problema
Simmetrica	Una chiave condivisa	Molto veloce, ideale per grossi volumi	Scambio sicuro della chiave
Asimmetrica	Coppia pubblica + privata	Non serve condividere un segreto a priori	Più lenta e computazionalmente costosa
Ibrida	Asimmetrica per scambiare una simmetrica	Pratica: combina i pregi delle due	Richiede certificati e protocolli corretti

 **Da ripetere** — Simmetrica: stessa chiave per cifrare e decifrare. Asimmetrica: chiave pubblica per cifrare, chiave privata per decifrare. Ibrida: asimmetrica per scambiare una chiave simmetrica di sessione, poi simmetrica per i dati.

Capitolo 7 — Firma digitale, hash, certificati e HTTPS

7.1 Firma digitale

La firma digitale non serve principalmente a nascondere un contenuto, ma a dimostrare chi lo ha firmato e che il contenuto non è stato modificato.

Lo schema tipico calcola prima un hash del documento e poi firma l'hash con la chiave privata del firmatario:

$$\sigma = \text{Sign}_{sk}(H(M))$$

La verifica avviene con la chiave pubblica del firmatario, controllando che il risultato corrisponda all'hash ricalcolato sul documento ricevuto:

$$\text{Verify}_{pk}(M, \sigma) = \text{TRUE} \Leftrightarrow H(M) \text{ coincide con } \text{Decrypt}_{pk}(\sigma)$$

In pratica:

- Alice prepara un messaggio o documento M .
- Alice calcola l'hash $H(M)$.
- Alice firma l'hash con la propria chiave privata.
- Bob ricalcola l'hash del documento ricevuto.
- Bob verifica la firma usando la chiave pubblica di Alice.
- Se gli hash coincidono, il documento è integro e la firma è valida.

Proprietà	Significato
Autenticità	Solo chi possiede la chiave privata poteva generare quella firma.
Integrità	Se il contenuto cambia, l'hash cambia e la verifica fallisce.
Non ripudio	Il firmatario non può negare facilmente la firma, se la chiave privata era sotto il suo controllo.

7.2 Certificati digitali e Autorità di Certificazione (CA)

Un certificato digitale è una sorta di carta d'identità elettronica di un sito o di un soggetto. Contiene il nome del sito o dell'entità, la chiave pubblica, il periodo di validità, l'autorità che lo ha emesso e la firma digitale dell'autorità di certificazione (CA).

Il browser non si fida del sito solo perché il sito si dichiara autentico: verifica che il certificato sia firmato da una CA presente nel proprio archivio di fiducia (trust store), che non sia scaduto né revocato e che il nome del sito visitato coincida con quello indicato nel certificato.

7.3 HTTPS

HTTPS è la versione sicura di HTTP. Protegge la comunicazione tra browser e server usando il protocollo TLS. Il server presenta un certificato, il browser lo verifica, quindi entrambi stabiliscono una chiave simmetrica di sessione attraverso uno scambio asimmetrico (*handshake*). Da quel momento i dati viaggiano cifrati e un attaccante sulla rete non dovrebbe poterli leggere né modificare.

 **Da ripetere** — La firma digitale garantisce autenticità, integrità e non ripudio. Un certificato lega una chiave pubblica a un'identità verificata. HTTPS protegge i dati in transito e aiuta a riconoscere il sito corretto.

Capitolo 8 — HTTP, MITM, VPN, social engineering e crittografia post-quantistica

8.1 HTTP e attacco Man-in-the-Middle

Con HTTP classico i dati viaggiano in chiaro. Un attaccante sulla stessa rete o lungo il percorso può leggerli e modificarli. Questo scenario si chiama Man-in-the-Middle (**MITM**): l'attaccante si interpone fra client e server, osserva lo scambio e può alterarlo. Un esempio tipico è l'iniezione di codice JavaScript malevolo in una pagina non protetta: l'utente vede una pagina apparentemente normale, ma il browser esegue codice aggiunto dall'attaccante, capace di rubare cookie o dati di sessione.

8.2 VPN

Una VPN (Virtual Private Network) crea un tunnel cifrato tra il dispositivo dell'utente e un server VPN. È utile quando si usa una rete non affidabile — ad esempio il Wi-Fi pubblico di un bar o di un aeroporto — oppure per accedere da remoto a una rete aziendale. La VPN protegge i dati in transito fino al server VPN, ma non rende sicuro un sito malevolo, non sostituisce antivirus, aggiornamenti o buon senso.

Cosa fa una VPN	Cosa NON fa una VPN
Cifra il traffico tra dispositivo e server VPN	Non impedisce di inserire dati in un sito falso
Riduce il rischio sulle reti pubbliche non affidabili	Non elimina malware già presenti sul dispositivo
Può mascherare l'IP verso il sito visitato	Non garantisce anonimato assoluto

8.3 Social engineering

Il social engineering è l'attacco all'essere umano. L'attaccante non forza necessariamente un sistema: convince una persona a fare qualcosa di pericoloso (fornire una password, installare software, cliccare un link, aprire un allegato, inviare denaro), sfruttando fiducia, fretta, paura, curiosità o desiderio di ricompensa. Esempi:

- Telefonata falsa dell'assistenza tecnica che invita a installare un software di controllo remoto.
- Messaggio urgente del tipo *“sono tuo figlio, ho cambiato numero, mandami soldi”*.
- Chiavetta USB lasciata in un luogo pubblico per sfruttare la curiosità di chi la trova.
- Plugin o estensione falsa che promette funzionalità utili ma ruba credenziali.

8.4 Crittografia post-quantistica (PQC)

I computer quantistici, sfruttando algoritmi come quello di Shor, potrebbero in futuro rendere vulnerabili alcuni algoritmi asimmetrici oggi diffusi, come RSA, Diffie-Hellman e la crittografia su curve ellittiche. La crittografia post-quantistica studia algoritmi progettati per resistere anche a un attaccante con computer quantistici potenti (per esempio schemi basati su reticoli, codici, hash). La transizione sarà graduale e in molti casi ibrida, combinando algoritmi classici e PQC nello stesso protocollo.

 **Da ripetere** — HTTP è una cartolina, HTTPS una busta sigillata e verificata. La VPN protegge la comunicazione ma non da ogni minaccia. Il social engineering può aggirare anche ottime difese tecniche. La crittografia deve evolvere perché gli strumenti d'attacco evolvono.

Parte II

Cybersecurity 2: privacy, software, blockchain e AI

Dopo aver capito identità digitale, crittografia e comunicazioni sicure, la Parte II amplia il punto di vista: cosa accade ai dati mentre navighiamo, come i software possono essere vulnerabili, perché le blockchain promettono fiducia senza autorità centrale e in che modo l'intelligenza artificiale cambia sia la difesa sia l'attacco.

Capitolo 9 — Privacy online: dati personali, consenso e profilazione

La privacy in rete riguarda il controllo delle informazioni personali: chi può accedere ai dati, come vengono raccolti, dove vengono conservati, per quanto tempo restano disponibili e per quale scopo vengono usati. Non significa solo “*avere qualcosa da nascondere*”: significa poter decidere cosa mostrare, a chi, in quale contesto e con quali limiti.

Ogni attività online lascia tracce: ricerche, click, acquisti, posizione, preferenze, tempo passato su una pagina, dispositivi usati, interazioni sui social.

Molti di questi dati vengono raccolti in modo poco visibile all’utente e poi combinati per costruire profili pubblicitari, commerciali o comportamentali.

 **Da ripetere** — Privacy non significa segretezza assoluta: significa controllo sulle informazioni personali. Un dato personale è qualsiasi informazione che identifichi una persona direttamente o indirettamente. La profilazione nasce dalla combinazione di molte tracce apparentemente piccole.

9.1 Perché difendere la privacy è difficile

I dati viaggiano attraverso molte infrastrutture, sono conservati su server diversi, vengono condivisi tra servizi e spesso costituiscono il prezzo nascosto di piattaforme apparentemente gratuite. Le informative sono lunghe e molti utenti cliccano “*accetta*” senza capire davvero cosa stiano autorizzando.

Privacy è diversa da segretezza

Dire “*non ho nulla da nascondere*” non risolve il problema. Anche informazioni normali possono diventare sensibili se aggregate: posizione, salute, interessi politici, abitudini, relazioni, orari e luoghi frequentati. La privacy protegge autonomia, libertà di scelta e dignità personale.

Capitolo 10 — Cookie, GDPR, log server e dati che restano online

I **cookie** sono piccoli file di testo che un sito salva nel browser.

Servono a ricordare informazioni utili: mantenere una sessione di login, salvare preferenze, ricordare il contenuto di un carrello o raccogliere dati statistici. Non tutti i cookie sono negativi: alcuni sono necessari al funzionamento del sito. Il problema nasce quando vengono usati in modo eccessivo o opaco per tracciare l'utente attraverso siti diversi.

Tipo di cookie	Funzione	Problema possibile
Sessione	Mantiene l'utente loggato mentre naviga	Se rubato, può consentire il furto di sessione
Preferenza	Ricorda lingua, tema, impostazioni	Meno invasivo, ma comunque traccia scelte
Analitico	Misura visite, pagine, tempo di permanenza	Può contribuire alla profilazione
Marketing / tracciamento	Segue l'utente per pubblicità personalizzata	È il più delicato per la privacy

10.1 GDPR in parole semplici

Il *GDPR* (*Regolamento UE 2016/679*) è il regolamento europeo sulla protezione dei dati personali. Il suo obiettivo è dare ai cittadini maggiore controllo sui propri dati e prevede una serie di diritti fondamentali.

Diritto	Significato
Informazione	Sapere chi raccoglie i dati e per quale scopo
Accesso	Sapere quali dati sono effettivamente conservati
Cancellazione / oblio	Chiedere la rimozione quando possibile
Portabilità	Trasferire i propri dati da un servizio a un altro
Opposizione	Opporsi a marketing o profilazione in determinati casi

10.2 Cancellare i cookie non cancella tutto

Eliminare i cookie dal browser rimuove file locali, ma non cancella necessariamente i dati già raccolti dal sito. I server possono conservare log e database con pagine visitate, azioni eseguite, indirizzi IP, orari, identificativi e preferenze.

Per questo i cookie sono solo la punta visibile di un sistema di raccolta dati più ampio.

 **Da ripetere** — I cookie sono file locali, ma i dati possono restare anche sui server. Il GDPR tutela il controllo sui dati personali. Cancellare i cookie aiuta, ma non elimina log e database già creati dal servizio.

Capitolo 11 — Cronologia, modalità privata e sincronizzazione cloud

La cronologia del browser è l'elenco dei siti visitati. È utile per ritrovare pagine e completare indirizzi, ma costituisce anche una traccia dettagliata della vita digitale. Su un computer condiviso può rivelare informazioni delicate: salute, lavoro, interessi personali, acquisti, relazioni o difficoltà economiche.

11.1 Perché la cronologia può essere rischiosa

- Su un computer condiviso, altre persone possono vedere siti visitati e ricerche.
- Un malware o un'estensione malevola può leggere la cronologia e ricostruire abitudini e interessi.
- La sincronizzazione cloud può far comparire la cronologia su più dispositivi collegati allo stesso account.
- In contesti lavorativi o scolastici, la cronologia può esporre attività personali.

11.2 Modalità privata: cosa fa e cosa non fa

La modalità privata (o *"incognito"*) riduce le tracce locali: di norma non salva cronologia, cookie permanenti e dati dei moduli dopo la chiusura della finestra. Però non rende anonimi su Internet: il sito visitato, il provider, la rete aziendale o scolastica e numerosi tracker possono comunque vedere parte dell'attività.

Modalità privata FA	Modalità privata NON FA
Non salva la cronologia locale della sessione	Non nasconde l'IP ai siti
Elimina molti cookie temporanei alla chiusura	Non impedisce il tracciamento lato server
Aiuta su dispositivi condivisi	Non blocca malware o phishing

 **Da ripetere** — La cronologia è una traccia della vita digitale e può violare la riservatezza. La modalità privata protegge soprattutto dalle tracce locali, non dall'intera rete. La sincronizzazione cloud può rendere la cronologia visibile su più dispositivi.

Capitolo 12 — Fingerprinting: l'impronta tecnica del browser

Il **fingerprinting** è una tecnica di identificazione che non usa necessariamente cookie o login. Un sito osserva caratteristiche tecniche del browser, del sistema operativo e del dispositivo — lingua, risoluzione, font installati, fuso orario, estensioni, scheda grafica, WebGL, WebRTC, Canvas, numero di core — e ne ricava una sorta di impronta digitale tecnica. Singolarmente questi dati sembrano innocui. Combinati, possono creare un'impronta molto precisa: anche se l'utente cancella i cookie o usa la modalità privata, l'impronta resta simile nel tempo e permette il riconoscimento.

Dato tecnico	Perché contribuisce all'impronta
Browser e versione	Non tutti usano la stessa configurazione
Sistema operativo	Restringe il gruppo di utenti possibili
Risoluzione e fuso orario	Collegano dispositivo e posizione approssimata
Font ed estensioni	Possono rendere la configurazione quasi unica
WebGL / Canvas	Rivelano dettagli grafici e hardware

12.1 Perché è un problema per la privacy

Il fingerprinting è invisibile, non si cancella facilmente come un cookie, funziona anche senza login e prosegue dopo aver svuotato cache e cookie. Alcuni browser orientati alla privacy cercano di ridurre o standardizzare le informazioni esposte, ma non esiste una difesa perfetta senza limitare alcune funzionalità del web.

 **Da ripetere** — Il fingerprinting identifica tramite caratteristiche tecniche, non solo tramite cookie. È una forma di tracciamento più invisibile e persistente. Difendersi richiede browser orientati alla privacy, blocco dei tracker e attenzione ai permessi concessi.

Capitolo 13 — Privacy nei social network

I social network raccolgono dati che l'utente pubblica volontariamente, ma anche dati generati dal comportamento: cosa guarda, per quanto tempo, con chi interagisce, cosa commenta, cosa mette tra i preferiti, dove si trova e quali dispositivi usa. La privacy sui social non dipende solo da quello che pubblichiamo noi, ma anche da quello che pubblicano gli altri su di noi e da quello che la piattaforma registra in background.

Rischio	Esempio	Contromisura
Eccessiva esposizione	Foto in vacanza con posizione in tempo reale	Pubblica in differita, limita il pubblico
Tag indesiderati	Un amico pubblica una foto che non volevi rendere pubblica	Attiva l'approvazione dei tag
Profilazione silenziosa	La piattaforma deduce interessi e abitudini dai comportamenti	Riduci permessi e pubblicità personalizzata
Persistenza dei contenuti	Un post eliminato può essere già stato salvato da altri	Pensa prima di pubblicare contenuti sensibili

Un principio utile è chiedersi: *“sarei tranquillo se questa informazione restasse online per anni o venisse vista fuori contesto?”*.

Se la risposta è **no**, è meglio non pubblicarla o limitarne molto la visibilità.

 **Da ripetere** — L'identità digitale è costruita anche da ciò che gli altri pubblicano su di noi. Nei social la privacy è sia tecnica sia sociale. Prima di pubblicare, immagina che il contenuto possa restare online molto più a lungo del previsto.

Capitolo 14 — Phishing: riconoscere l’inganno

Il **phishing** è una tecnica di attacco in cui l’attaccante finge di essere un soggetto affidabile — banca, università, corriere, ente pubblico, servizio online — per convincere l’utente a consegnare informazioni riservate: password, codici OTP, dati di carta, documenti o credenziali aziendali. Il termine richiama l’idea di pescare: l’attaccante lancia l’amo e aspetta che qualcuno abbocchi.

14.1 Segnali tipici di un’email di phishing

- Urgenza o minaccia: “il conto verrà bloccato”, “agisci subito”, “accesso sospetto rilevato”.
- URL sospetti: domini strani, trattini, errori, lettere simili (omoglifi), indirizzi non ufficiali.
- Richiesta di dati sensibili: una banca seria non chiede password o OTP via email.
- Errori grafici o linguistici: loghi sgranati, traduzioni strane, impaginazione sospetta.
- Allegati inattesi: fatture, documenti o file compressi non richiesti.

14.2 Email legittima vs phishing

Aspetto	Email legittima	Phishing
Mittente	Dominio ufficiale e coerente	Dominio simile ma falso o mascherato
Tono	Informativo, non aggressivo	Urgente, minaccioso, emotivo
Link	Invita a usare canali ufficiali	Spinge a cliccare subito
Dati richiesti	Non chiede password / OTP	Chiede credenziali, carte, codici

Regola pratica

Non inserire mai password o codici OTP dopo aver cliccato un link ricevuto via email, SMS o chat. Apri il sito digitando l’indirizzo nel browser o usando l’app ufficiale già installata. In caso di dubbio, contatta il servizio tramite numeri e indirizzi presi dal sito ufficiale, mai dal messaggio sospetto.

 **Da ripetere** — Il phishing non rompe la crittografia: inganna l’utente perché consegni il segreto. Urgenza, paura e link sospetti sono segnali tipici. Nessun servizio serio chiede password o OTP via email.

Capitolo 15 — Injection: SQL injection, command injection e XSS

Gli attacchi di **injection** avvengono quando un'applicazione tratta come affidabile un input fornito dall'utente.

L'attaccante inserisce comandi malevoli in campi che dovrebbero contenere solo dati: *form di login, barre di ricerca, URL, commenti, parametri di richiesta*.

Il software interpreta quei comandi come legittimi ed esegue operazioni non previste.

Tipo	Come funziona	Obiettivo tipico
SQL Injection	Inserisce codice SQL in input destinati al database	Leggere, modificare o cancellare dati
Command Injection	Fa eseguire comandi del sistema operativo	Accedere a file, controllare il server
XSS	Inietta JavaScript in una pagina vista da altri utenti	Rubare cookie, sessioni o mostrare contenuti falsi

15.1 XSS in parole semplici

Nel **Cross-Site Scripting** un attaccante riesce a salvare o inserire JavaScript malevolo in una pagina. Quando un altro utente visita quella pagina, il suo browser esegue lo script. Lo script può rubare cookie di sessione, inviare dati a un server esterno o modificare ciò che l'utente vede. Esempio concettuale:

un forum permette commenti ma non filtra correttamente il contenuto. L'attaccante inserisce un *tag* `<script>` che invia `document.cookie` a un dominio controllato da lui. Quando altri utenti aprono il post, il loro browser esegue il codice.

15.2 Difese principali

- Validare e sanificare sempre gli input: non fidarsi mai dei dati provenienti dall'utente.
- Usare query parametrizzate (prepared statements) per evitare SQL injection.
- Eseguire l'escaping dell'output HTML per mitigare XSS.
- Limitare i privilegi del database e del processo server: se avviene una vulnerabilità, il danno deve restare contenuto.
- Applicare security by design: la sicurezza si progetta dall'inizio, non si aggiunge alla fine.

 **Da ripetere** — Un'injection trasforma un input in un comando malevolo. La causa tipica è fidarsi troppo dei dati forniti dall'utente. Validazione, query parametrizzate, escaping e minimo privilegio sono difese fondamentali.

Capitolo 16 — Software, trust, sandbox e aggiornamenti

Il software è ovunque: *browser, app, banche, scuole, sanità, automobili, aerei, dispositivi medici*. Ci fidiamo del software perché ci aspettiamo che faccia ciò che promette e che non esponga i nostri dati. Questa fiducia si chiama *trust*, ma non deve essere cieca: anche software di aziende note o progetti open source molto diffusi possono contenere vulnerabilità. Molti attacchi informatici sfruttano bug nel codice. Per questo la sicurezza del software è centrale: *non basta proteggere la rete se l'applicazione accetta input pericolosi, conserva dati male o concede troppi permessi*.

16.1 Sandbox

Una **sandbox** è un ambiente isolato. L'idea è confinare un'applicazione o una sua parte dentro una "scatola" con permessi limitati: se quella parte viene compromessa, l'attaccante non dovrebbe poter prendere il controllo dell'intero sistema. Browser moderni, sistemi operativi mobili e contenitori (container, virtual machine) implementano forme diverse di sandboxing.

16.2 Aggiornamenti e vulnerabilità

Gli **aggiornamenti** non servono solo ad aggiungere funzionalità: spesso correggono vulnerabilità note. Rimandare aggiornamenti importanti lascia aperte porte che gli attaccanti conoscono. Vale per sistema operativo, browser, app, plugin, router, dispositivi IoT e librerie software usate dagli sviluppatori.

 **Da ripetere** — Un software affidabile non deve solo funzionare bene, ma anche resistere agli attacchi. La sandbox limita i danni di una compromissione. Gli aggiornamenti sono una difesa: correggono vulnerabilità sfruttabili.

Capitolo 17 — Security by design e principi di progettazione sicura

Security by design significa progettare la sicurezza fin dall'inizio. Non si costruisce prima il software e poi si aggiunge sicurezza come decorazione finale. È come progettare una casa pensando subito a porte, serrature, vie di fuga e impianto elettrico: se ci si pensa dopo, correggere costa di più e funziona peggio.

17.1 Principi fondamentali

Principio	Significato	Esempio
Minimo privilegio	Ogni componente ha solo i permessi necessari	Un modulo di report non deve poter cancellare utenti
Validazione input	Controllare tutto ciò che arriva da fuori	Bloccare input che sembrano comandi SQL
Difesa in profondità	Più barriere successive	MFA + logging + rate limit + backup
Crittografia	Proteggere dati a riposo e in transito	Database cifrato e HTTPS
Logging e monitoraggio	Rilevare anomalie e incidenti	Alert su accessi impossibili o troppi errori
Fail secure	In caso di errore, il sistema resta chiuso	Se il controllo fallisce, non concedere accesso

17.2 Perché costa meno pensarci prima

Correggere una vulnerabilità dopo il rilascio richiede patch, migrazioni, comunicazioni agli utenti, gestione di incidenti e danni reputazionali. Progettare in modo sicuro all'inizio costa meno che riparare dopo un attacco. La security by design è una mentalità prima ancora che una tecnica.

 **Da ripetere** — Security by design significa pensare la sicurezza dall'inizio del progetto. Non è un'aggiunta finale: è parte dell'architettura. Minimo privilegio, validazione degli input e difesa in profondità sono principi essenziali.

Capitolo 18 — Blockchain: registro distribuito, consenso, Proof of Work e mining

Una **blockchain** è un registro digitale condiviso tra molti partecipanti.

Le informazioni sono organizzate in blocchi collegati in ordine cronologico: ogni blocco contiene dati e un riferimento crittografico (*l'hash*) al blocco precedente. Questo rende difficile modificare un blocco senza che la modifica diventi visibile a tutta la rete.

Le blockchain sono spesso associate alle criptovalute, ma il concetto è più ampio: possono essere viste come un paradigma per progettare servizi software decentralizzati, dove non esiste un'unica autorità centrale che controlla il registro.

18.1 Consenso

In una rete decentralizzata non basta che un singolo partecipante dica “questo blocco è valido”. I nodi devono raggiungere consenso, cioè accordarsi su quale sia lo stato corretto del registro. Il problema è difficile perché alcuni partecipanti possono essere malevoli (modello bizantino) e perché non si può semplicemente contare un voto per persona: un attaccante potrebbe creare molte identità false (attacco Sybil).

18.2 Proof of Work e mining

Nella **Proof of Work (PoW)** il consenso si lega alla potenza computazionale.

I **miner** provano molti valori di un parametro detto *nonce* finché l'hash del blocco soddisfa una condizione, ad esempio iniziare con un certo numero di zeri:

$$H^2(\text{blocco} || \text{nonce}) < T$$

dove **T** è un valore di soglia che fissa la difficoltà.

È un puzzle che si risolve per tentativi: trovare il blocco valido è costoso, verificare che lo sia è quasi immediato.

Termine	Spiegazione semplice
Hash	Impronta crittografica del contenuto: cambia se cambia anche un solo bit
Nonce	Numero modificato ripetutamente per cercare un hash valido
Mining	Processo di ricerca del nonce corretto
Proof of Work	Prova che è stato svolto lavoro computazionale
Consenso	Accordo dei partecipanti sullo stato corretto della catena

² **H**: sarebbe inteso come funzione hash

18.3 Vantaggi e limiti

Aspetto positivo	Problema o limite
Non serve una singola autorità centrale	Governance e responsabilità sono più complesse
Le modifiche sono difficili da nascondere	Se un dato sbagliato entra, eliminarlo è difficile
Trasparenza e verificabilità	Privacy e riservatezza non sono automatiche
Resistenza alla manipolazione	La PoW può consumare moltissima energia

 **Da ripetere** — Una blockchain è un registro distribuito di blocchi collegati da hash. Il consenso fa concordare i nodi sulla stessa versione della verità. La PoW rende costoso aggiungere blocchi falsi ma è energivora. Blockchain non significa automaticamente sicurezza perfetta: vanno valutati contesto, privacy, costi e governance.

Capitolo 19 — Intelligenza artificiale e cybersecurity

L'intelligenza artificiale è una tecnologia a doppio uso: può aiutare a difendere i sistemi, ma può anche aiutare gli attaccanti. In cybersecurity questo è particolarmente evidente: gli stessi strumenti che analizzano grandi quantità di dati per trovare anomalie possono essere usati per creare phishing più credibili o automatizzare parti di un attacco.

19.1 AI per la difesa

- Rilevamento di anomalie nel traffico di rete o nel comportamento degli utenti.
- Analisi di grandi quantità di log per trovare segnali di compromissione.
- Automazione di risposte (ad esempio l'isolamento di una macchina sospetta).
- Protezione dell'identità tramite biometria o analisi comportamentale.
- Supporto agli analisti nel classificare eventi e prioritizzare incidenti.

19.2 AI per l'attacco

- Phishing scritto meglio, personalizzato e privo di errori evidenti.
- Deepfake audio o video per impersonare persone reali.
- Automazione della ricognizione e della raccolta informazioni (*OSINT*).
- Generazione o adattamento di codice malevolo.
- Manipolazione di modelli e dati: prompt injection, avvelenamento (*data poisoning*), evasion.

 **Da ripetere** — L'AI in cybersecurity è una tecnologia a doppio uso. La difesa la usa per rilevare anomalie, automatizzare risposte e proteggere identità. Gli attaccanti la usano per phishing, deepfake e automazione. L'AI non sostituisce la responsabilità umana: richiede verifica e controllo.

Capitolo 20 — Cybersecurity del futuro: prevenzione, rilevamento, risposta, resilienza

Il futuro della cybersecurity non può essere visto come una semplice protezione tecnica gestita solo da specialisti. Più il digitale entra in sanità, scuola, pubblica amministrazione, trasporti e servizi quotidiani, più la sicurezza diventa una responsabilità collettiva. Ogni cittadino digitale è sia un possibile bersaglio sia una possibile difesa.

20.1 Dalla sicurezza assoluta alla resilienza

Non esiste un sistema perfetto e invulnerabile. Ogni sistema complesso può contenere vulnerabilità. L'obiettivo realistico non è eliminare ogni rischio, ma ridurlo, rilevare rapidamente gli incidenti, limitare i danni e ripristinare i servizi. Questa capacità si chiama resilienza.

Fase	Domanda	Esempio
Prevenzione	Come riduco la probabilità dell'attacco?	Security by design, MFA, aggiornamenti, formazione
Rilevamento	Come mi accorgo che qualcosa non va?	Log, monitoraggio, anomaly detection
Risposta	Come limito il danno?	Isolamento sistemi, revoca credenziali, incident response
Resilienza	Come continuo o riparto?	Backup, disaster recovery, comunicazione chiara

20.2 Scenari critici

In sanità digitale un attacco può bloccare macchinari, alterare dati clinici o ritardare diagnosi.

Nei servizi pubblici può impedire l'accesso a documenti, pagamenti o identità digitali.

Nei trasporti e nei dispositivi intelligenti può produrre effetti fisici. La cybersecurity non significa più solo proteggere file: significa proteggere servizi essenziali e persone.

 **Da ripetere** — La sicurezza assoluta non esiste: esiste una gestione consapevole del rischio. Prevenzione, rilevamento, risposta e resilienza sono le quattro parole chiave del futuro. La cybersecurity è una cultura diffusa: ogni utente può essere bersaglio, ma anche difesa.

Mappe finali dei concetti

Mappa Cybersecurity 1

Area	Concetti da collegare
Identità digitale	Account, autenticazione, autorizzazione, minimo privilegio
Accesso	Password robuste, password manager, MFA, SPID
Crittografia	Algoritmo pubblico, chiave segreta, simmetrica, asimmetrica, ibrida
Verifica	Hash, firma digitale, certificati, CA
Comunicazioni	HTTP, HTTPS, TLS, MITM, VPN
Fattore umano	Social engineering, phishing, consapevolezza

Mappa Cybersecurity 2

Area	Concetti da collegare
Privacy	Dati personali, consenso, profilazione, GDPR
Tracciamento	Cookie, cronologia, log server, fingerprinting
Social e phishing	Esposizione personale, tag, URL sospetti, urgenza, OTP
Software	Trust, vulnerabilità, sandbox, aggiornamenti, injection
Progettazione	Security by design, minimo privilegio, input validation, difesa in profondità
Tecnologie emergenti	Blockchain, consenso, Proof of Work, AI difensiva e offensiva